

## MAINCRAFTS TECHNOLOGY

Cybersecurity Analyst Internship

# THREAT INTELLIGENCE REPORT

Modern Cybersecurity Threats: 2024–2025

Task 1:

You are working as a Cybersecurity Analyst Intern at a company (simulation). Your manager has asked you to prepare a Threat Intelligence Report highlighting the latest cybersecurity threats (2024–2025) and possible defense measures.

Name

NEEL VIRALBHAI PATEL

# Table of Contents

---

- 1. Executive Summary**
- 2. Introduction to Cybersecurity**
  - 2.1 What is Cybersecurity?
  - 2.2 Importance for Individuals and Businesses
  - 2.3 Current Relevance and Growing Threat Landscape
- 3. Threat Analysis**
  - 3.1 AI-Powered Phishing Attacks
  - 3.2 Ransomware-as-a-Service (RaaS)
  - 3.3 Cloud Security Misconfigurations
  - 3.4 IoT Vulnerabilities
  - 3.5 Zero-Day Exploits
- 4. Threat Comparison Summary**
- 5. Conclusion and Future Scope**
- 6. References**

# 1. Executive Summary

---

## OVERVIEW

This report was put together as part of the Task 1 assignment for the Maincrafts Technology Cybersecurity Analyst Internship. The goal was straightforward: research five major threats currently shaping the cybersecurity landscape, look at real incidents where these threats caused actual damage, and think through what organizations can realistically do to defend themselves.

What struck me most while researching this is how fast things are changing. A few years ago, phishing emails were easy to spot — bad grammar, generic greetings, suspicious links. Today, attackers are using AI tools to write messages that are genuinely hard to distinguish from the real thing. Ransomware has gone from a niche criminal tool to basically a franchise business model. Cloud misconfigurations are leaking millions of records because teams move fast and don't always check their settings. The threat landscape in 2024-2025 is bigger, messier, and more creative than it's ever been.

This report covers five specific threats: AI-Powered Phishing, Ransomware-as-a-Service (RaaS), Cloud Security Misconfigurations, IoT Vulnerabilities, and Zero-Day Exploits. For each one, I've tried to go beyond the technical definition and explain why it matters, what a real breach actually looked like, and what steps genuinely help. The case studies are all documented incidents — not hypotheticals.

## 2. Introduction to Cybersecurity

---

### 2.1 What is Cybersecurity?

At its core, cybersecurity is about keeping digital systems — networks, devices, applications, and the data inside them — safe from people who should not have access. But it is more nuanced than just building walls. Security professionals think in terms of three goals: keeping data confidential, maintaining integrity (meaning data has not been secretly altered), and ensuring availability so systems actually work when people need them. This is usually called the CIA triad, and most real-world attacks are trying to violate at least one of those three things.

It is also worth noting that cybersecurity is not purely a technology problem. It cuts across IT, legal, HR, finance, and executive leadership. A phishing email that tricks a finance employee into wiring money is technically simple — but it bypasses every firewall in the building. The human element is very often where breaches actually happen, which is part of what makes this field so interesting to study.

### 2.2 Importance for Individuals and Businesses

Cybersecurity matters for pretty much everyone now, not just large corporations or government agencies. The risks are real and hit at very different levels:

- Regular people deal with things like identity theft, drained bank accounts, hacked social media, and — increasingly — ransomware locking up their personal files. Recovering from identity fraud can take months.
- Small businesses are arguably the most vulnerable group. Studies have found that around 60% of SMBs that suffer a significant attack end up closing within six months — not necessarily because the attack destroyed everything, but because of the combined weight of downtime, lost data, customer trust issues, and recovery costs.
- Larger companies face a different set of headaches: regulatory fines (GDPR violations can cost up to 4% of global annual revenue), class-action lawsuits, stock price drops, and reputational damage that can linger for years after a breach becomes public.
- And then there are sectors where the stakes go well beyond money — hospitals, power grids, water systems, financial infrastructure. When these get hit, it can genuinely endanger lives, not just bank accounts.

## 2.3 Current Relevance and Growing Threat Landscape

According to Cybersecurity Ventures, the global cost of cybercrime was projected to hit \$10.5 trillion annually by 2025 — up from \$3 trillion back in 2015. That kind of growth is staggering, and it reflects several shifts happening at the same time:

- **AI is making attacks cheaper and smarter:** Tools like WormGPT let criminals produce convincing phishing emails at scale, clone voices for fraud calls, and even generate working malware — no deep technical knowledge required.
- **The attack surface keeps growing:** Remote work normalized cloud tools and personal devices connecting to corporate networks. IoT devices are everywhere. Every new connection is a potential entry point, and most organizations have lost track of how many they actually have.
- **Cybercrime has been democratized:** Ransomware kits, phishing templates, and stolen credential databases are all available on dark web marketplaces. Someone with very limited technical skill can now run a reasonably sophisticated attack campaign.
- **Geopolitics has moved online:** Nation-state hacking — Russia, China, Iran, North Korea — is no longer rare. State-sponsored groups attack critical infrastructure, steal intellectual property, and run disinformation campaigns. The line between espionage and cybercrime has blurred considerably.

### 3. Threat Analysis

Below is a detailed breakdown of each of the five threats. For every threat, I have tried to explain how it actually works (not just the buzzword definition), point to a real case where it caused serious damage, break down who gets hurt and how, and then suggest defenses that are realistic rather than just theoretical.

#### 3.1 AI-Powered Phishing Attacks

THREAT 01 | AI-POWERED PHISHING ATTACKS

Phishing has been around since the early internet — the idea of tricking someone into handing over passwords or clicking a bad link is not new. What has changed drastically is how convincing these attacks have become. Traditional phishing emails were often obvious: broken English, generic greetings like Dear Customer, and links that looked wrong on closer inspection. Most people learned to spot them. But now attackers are using generative AI tools to write emails that read exactly like something your boss or your bank would actually send. The grammar is perfect, the tone is right, the details are specific to you. SlashNext reported a 1,200% increase in AI-generated phishing emails in 2024 compared to the year before. That is not a typo. Beyond email, attackers are cloning voices to run phone scams (known as vishing), using deepfake video to impersonate executives, and deploying chatbots that can hold a convincing multi-message conversation to extract credentials. The human brain was not built to be skeptical of every message it receives — and that is exactly what makes this threat so effective.

#### REAL-WORLD CASE STUDY

WormGPT (2023-2024): Security researchers found a tool called WormGPT being sold on dark web forums. Unlike ChatGPT or similar tools, WormGPT had no content restrictions — it was specifically trained on malware datasets and designed to help criminals. It could write Business Email Compromise emails in multiple languages with no grammatical errors, tailored to whatever target the attacker had in mind.

In documented cases, finance employees received AI-written emails impersonating their CFO and approved wire transfers running into hundreds of thousands of dollars. There was nothing obvious to flag the emails as fake.

Hong Kong Deepfake CFO Fraud (2024): This one is hard to believe until you read the details. A finance employee at a multinational firm was invited to a video conference. Everyone else on the call — including the company CFO — was an AI-generated deepfake. The employee was convinced the call was real and approved a transfer of \$25 million USD. It remains one of the largest deepfake fraud cases ever recorded.

#### IMPACT ANALYSIS

| Category   | Impact Details                                                                                                                                |
|------------|-----------------------------------------------------------------------------------------------------------------------------------------------|
| Individual | For regular people, the most common outcomes are stolen passwords, wiped bank accounts, compromised email that then gets used to attack their |

|                     |                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|---------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                     | contacts, and sometimes ransomware installed through a malicious attachment. Even a single successful phishing hit can spiral — one leaked password often unlocks several accounts if someone reuses credentials.                                                                                                                                                                                                                   |
| <b>Organization</b> | BEC attacks cost businesses an average of \$125,000 per incident according to FBI data — but the big cases go much higher. Beyond the direct financial hit, breached organizations often face regulatory action (especially if customer data was exposed), negative press coverage, and the slow erosion of trust from partners and clients who start wondering whether they should be sharing sensitive documents with you at all. |

## PREVENTIVE MEASURES

- **Email Security Filtering:** Tools like Proofpoint or Microsoft Defender for Office 365 analyze sender patterns, flag domain spoofing, and can quarantine suspicious messages before they reach the inbox. Not foolproof, but they catch a lot.
- **Phishing Simulation Training:** Regular simulated phishing exercises — where staff receive fake phishing emails and are coached when they click — are genuinely effective at building habits. People learn faster when they experience a (safe) near-miss.
- **Multi-Factor Authentication (MFA):** Even if a password gets stolen, MFA stops the attacker from actually using it. This single control blocks the vast majority of credential-based account takeovers. It should be mandatory across all accounts, not just email.
- **Out-of-Band Verification:** Any financial transfer or sensitive request received by email or message should require a separate verification step — a phone call to a known number, for example. If someone asks you to wire money via email, call them directly before doing anything.

## 3.2 Ransomware-as-a-Service (RaaS)

### THREAT 02 | RANSOMWARE-AS-A-SERVICE (RaaS)

Ransomware locks your files using encryption and demands payment — usually cryptocurrency — to restore access. That basic formula has been around for years. What changed is the business model around it. Ransomware-as-a-Service works the same way legitimate SaaS does: a group of skilled developers builds and maintains the ransomware toolkit, then rents it out to affiliates — people who run the actual attacks and split the ransom proceeds with the developers. The affiliates do not need to know how to code. They just need to find a way in. This has turned ransomware from something only sophisticated hackers could pull off into something almost anyone with basic technical know-how can attempt. Modern RaaS operations are genuinely professional — some include customer support portals where victims can negotiate the ransom, FAQs, and even test decryption of a single file to prove they can deliver what they promise. Many groups have also moved to double extortion: they encrypt your files AND steal them first, so even if you restore from backup, they can still threaten to publish your data publicly.

## REAL-WORLD CASE STUDY

WannaCry (2017): WannaCry was not technically a RaaS attack, but it showed the world what mass-scale ransomware damage looks like. It used EternalBlue, an exploit developed by the NSA that was leaked online, to spread automatically across networks without any user interaction needed. Within 72 hours it had infected over 200,000 systems across 150 countries.

The UK National Health Service was hit hard — around 80 NHS trusts were affected, thousands of appointments were cancelled, some A&E departments had to turn patients away, and the eventual cost was estimated at around 92 million pounds. For a ransomware attack, those are not just financial losses. Those are patients.

Colonial Pipeline (2021): The DarkSide RaaS group hit Colonial Pipeline, which moves about 45% of fuel to the U.S. East Coast. The company paid a \$4.4 million ransom (some of which was later recovered by the FBI) and shut down operations for six days. Fuel shortages spread across multiple states. Gas station lines formed. It was a vivid demonstration of how ransomware hitting the wrong target becomes a public crisis.

LockBit (2023-2024): LockBit became arguably the most prolific ransomware operation in history, responsible for over 1,700 documented attacks on hospitals, law firms, schools, and government agencies. They offered their ransomware kit to affiliates on a subscription basis, ran a leak site where they published stolen data, and even had a bug bounty program — offering cash rewards to researchers who found flaws in their own software.

## IMPACT ANALYSIS

| Category     | Impact Details                                                                                                                                                                                                                                                                                                                                                                                                        |
|--------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Individual   | If ransomware hits a personal computer and there is no backup, the photos, documents, and files can simply be gone — unless you pay. Demands targeting individuals typically range from a few hundred to a few thousand dollars. Even then, not all attackers follow through with decryption after payment. It is a gamble either way.                                                                                |
| Organization | Average ransom payments hit \$812,000 in 2024, but the ransom is often just a portion of the total cost. Downtime averages around 21 days per incident, which for a mid-sized business can run into millions of lost revenue. There are also forensics costs, legal fees, potential regulatory fines (especially in healthcare or finance), and the uncomfortable conversations with customers whose data got stolen. |

## PREVENTIVE MEASURES

- **Reliable, Tested Backups:** The 3-2-1 rule is the baseline: three copies of data, two different storage types, one offsite or offline. More importantly — test your restores regularly. A backup you have never tested is not a backup you can trust when you actually need it.
- **Network Segmentation:** If ransomware gets onto one machine, segmentation slows or stops it spreading to the whole network. Keeping systems separated — especially critical servers from general user workstations — limits the blast radius significantly.
- **Endpoint Detection and Response (EDR):** EDR tools monitor for suspicious behavior in real-time (like a process suddenly encrypting thousands of files) and can automatically isolate an infected machine before the ransomware spreads. This is much more effective than traditional antivirus.
- **Patch Management:** WannaCry spread through an unpatched vulnerability. So did several other major outbreaks. Applying critical security patches within a day or two of release closes

the most common entry points ransomware groups rely on. It sounds basic because it is — but it works.

### 3.3 Cloud Security Misconfigurations

THREAT 03 | CLOUD SECURITY MISCONFIGURATIONS

Practically every organization has moved some workload to cloud platforms — AWS, Azure, GCP, or all three. That shift has brought enormous benefits, but it has also introduced a category of vulnerability that is embarrassingly common and preventable: misconfiguration. Cloud environments are genuinely complex. There are thousands of settings across dozens of services, and teams are often moving fast. A storage bucket left publicly accessible. An IAM role with permissions far wider than it needs. A database sitting exposed without encryption. An API with no authentication. These are not exotic vulnerabilities — they do not require a sophisticated attacker to exploit. In many cases, someone can simply search the internet for exposed buckets using publicly available tools and stumble across sensitive data without any hacking at all. The core issue is the shared responsibility model. Cloud providers secure the infrastructure; customers are responsible for securing what they put on it. That distinction is clear in the documentation but easy to lose track of when you are moving quickly and your team is stretched.

#### REAL-WORLD CASE STUDY

Capital One (2019): A former AWS employee exploited a misconfigured Web Application Firewall — specifically a Server-Side Request Forgery (SSRF) flaw — to query AWS metadata services and collect temporary credentials. Using those, she pulled data from over 700 S3 buckets.

The breach exposed personal details for approximately 100 million people in the US and 6 million in Canada — Social Security numbers, bank account numbers, credit scores. Capital One paid \$80 million in regulatory fines and spent an estimated \$300 million or more on remediation. The sobering part: Capital One was not a small company with no security resources. They had dedicated cloud security teams. Misconfiguration happened anyway.

Microsoft Power Apps (2021): Researchers at UpGuard found that approximately 38 million records from 47 organizations were publicly accessible because Microsoft Power Apps portals had a default setting that made data tables public. Affected organizations included American Airlines, Ford, and the Indiana Department of Health. Many of them had no idea the data was exposed.

#### IMPACT ANALYSIS

| Category   | Impact Details                                                                                                                                                                                                              |
|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Individual | People whose data ends up in a misconfigured cloud bucket often have no idea anything went wrong — that is the unsettling part. Their Social Security numbers, health records, or financial details may be sitting publicly |



|                     |                                                                                                                                                                                                                                                                                                                                                                                                                 |
|---------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                     | accessible on the internet without a single alert going off anywhere. The harm shows up later: identity fraud, unauthorized credit applications, accounts opened in their name.                                                                                                                                                                                                                                 |
| <b>Organization</b> | Regulatory consequences are significant — GDPR penalties can reach 4% of global annual revenue, and healthcare breaches in the US carry HIPAA fines on top of that. But the less measurable cost is often bigger: the months spent in incident response, the lawyers, the mandatory breach notifications to regulators and affected customers, and the reputational hit that follows when news breaks publicly. |

## PREVENTIVE MEASURES

- **CSPM Tools:** Cloud Security Posture Management tools like Wiz, Prisma Cloud, or AWS Security Hub continuously scan your cloud environment for misconfigurations and flag them before an attacker does. They are not a silver bullet, but they catch a surprising amount of obvious mistakes automatically.
- **Least Privilege Everywhere:** Every IAM role, service account, and API key should have only the permissions it actually needs for its specific job — nothing more. This is tedious to get right but critical. Over-permissioned roles are one of the main ways a small misconfiguration turns into a massive breach.
- **Shift-Left Security Scanning:** Tools like Checkov can scan infrastructure-as-code templates (Terraform, CloudFormation) before anything gets deployed. Catching a misconfiguration in a template before it reaches production is a lot easier than finding it after the fact.
- **Routine Configuration Reviews:** Cloud environments drift. What was correctly configured six months ago may not be now — teams add resources, change settings, forget to revisit old policies. Scheduled reviews against something like the CIS Cloud Benchmarks help catch drift before it becomes a problem.

## 3.4 IoT Vulnerabilities

### THREAT 04 | IoT VULNERABILITIES

IoT — the Internet of Things — refers to the enormous category of physical devices that connect to the internet and communicate with each other or with remote servers. Smart speakers, home security cameras, baby monitors, industrial sensors, hospital equipment, building management systems, traffic lights. The list goes on, and the numbers are large: IoT Analytics estimated over 18 billion connected IoT devices globally by 2025. Here is the problem with most of them: security was clearly not the top priority when they were designed. Manufacturers were focused on getting products to market cheaply and quickly. The result is devices that often ship with default credentials like admin/admin or root/password, run on operating systems that stopped receiving patches years ago, send data unencrypted, have no way to receive firmware updates, and cannot run any kind of security software. They are essentially tiny, always-on computers with no security, permanently connected to the internet, sitting inside your home or office network. Attackers love them. They are easy to compromise at scale, useful for building botnets (networks of hijacked devices used to launch attacks), and once inside a network through an IoT device, attackers can pivot to attack other systems on the same network.

## REAL-WORLD CASE STUDY

**Mirai Botnet (2016):** Mirai was a piece of malware that did something simple and devastating. It scanned the internet looking for IoT devices — cameras, DVRs, routers — that still had their default login credentials. When it found one, it logged in, added the device to a botnet, and moved on to the next. It compiled a botnet of over 600,000 devices.

That botnet was then pointed at Dyn, one of the internet's major DNS providers. The resulting DDoS attack hit traffic volumes above 1.2 Tbps — more than most networks had ever seen — and knocked out major sites including Twitter, Netflix, Reddit, CNN, and GitHub for hours across North America and Europe. Hundreds of thousands of unsecured cameras and routers effectively took down a significant chunk of the internet.

**Verkada Camera Breach (2021):** A hacker group gained access to a super-admin account at Verkada, a security camera company. That single access point gave them live feeds from 150,000 cameras installed in hospitals, prisons, schools, police departments, and Tesla manufacturing facilities. It was not a sophisticated exploit — they found exposed credentials online. The cameras were there, accessible, and nobody noticed until after the damage was done.

## IMPACT ANALYSIS

| Category     | Impact Details                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|--------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Individual   | For homeowners, the most immediate risks are privacy-related — someone watching through your security camera, or listening through a compromised smart speaker. Smart locks and alarm systems being accessed remotely are also a concern. Many people would be shocked to find out their home camera or baby monitor has been part of a botnet for months without any visible sign.                                                                                                            |
| Organization | Enterprises that deploy IoT devices without proper security controls are handing attackers a soft entry point into otherwise well-protected networks. Industrial environments face even higher stakes — compromised OT (operational technology) systems can cause physical disruptions, production shutdowns, or in extreme cases, safety incidents. Healthcare organizations using connected medical devices face both patient safety risks and HIPAA exposure if those devices get breached. |

## PREVENTIVE MEASURES

- **Change Default Credentials:** Every IoT device that ships with default credentials like admin/admin should have those changed before the device ever connects to a real network. This single step would have prevented the Mirai botnet from compromising most of its victims. It sounds absurdly basic — because it is.
- **Put IoT on Its Own Network Segment:** Create a separate VLAN specifically for IoT devices. That way, if a smart thermostat or a printer gets compromised, the attacker cannot immediately pivot to your file servers or HR systems. Isolation limits the damage.
- **Track and Update Firmware:** Keep a list of every IoT device deployed, check vendor advisories for security updates, and actually apply firmware updates when they come out. Devices that have stopped receiving updates from manufacturers should be considered for replacement.

- **Assess Before You Deploy:** Before buying and installing IoT devices — especially in sensitive environments — check whether they can receive updates, what their default security settings look like, and whether the vendor has a documented security program. The OWASP IoT Attack Surface Areas document is a useful reference for what to look for.

## 3.5 Zero-Day Exploits

### THREAT 05 | ZERO-DAY EXPLOITS

A zero-day is a vulnerability in software or hardware that the vendor does not know about yet — so by definition, there is no patch available when it is first discovered and used. The name comes from the fact that developers have had zero days to fix it. These are the most dangerous class of security flaw because the normal advice — update your software, apply patches — literally does not apply. There is nothing to apply yet. Zero-day exploits are extremely valuable. Reputable brokers like Zerodium pay millions of dollars for working zero-days in popular software. Nation-state intelligence agencies stockpile them for offensive operations. Criminal groups use them in targeted attacks before the window closes (which is what happens once the vendor finds out and releases a patch). The really damaging ones are those that get quietly used for months or years before anyone notices — which is exactly what happened with SolarWinds.

### REAL-WORLD CASE STUDY

**SolarWinds / SUNBURST (2020-2021):** This is arguably the most consequential cyberattack in recent history. Attackers — believed to be Russian SVR intelligence — did not hack SolarWinds directly. They compromised the company's software build pipeline and inserted a backdoor into Orion, a widely used IT monitoring product, before the update was signed and shipped to customers.

Around 18,000 organizations installed the poisoned update. The SUNBURST backdoor sat quietly for two weeks after installation, then began communicating with attacker-controlled servers. It exfiltrated sensitive data from U.S. government departments (Treasury, Commerce, State, Homeland Security, Defense), Microsoft, Intel, Cisco, and others — for months without being detected. The whole thing went unnoticed for roughly nine months before a private cybersecurity firm noticed something unusual in their own network.

The full damage has never been publicly disclosed. The attack triggered major reviews of U.S. federal cybersecurity policy, executive orders, and billions in new government security spending.

**MOVEit (2023):** The CL0P ransomware group exploited a zero-day SQL injection flaw in MOVEit Transfer, a widely used managed file transfer tool. They hit over 2,500 organizations in a short window — banks, healthcare providers, government agencies, universities. Over 67 million individuals had data exposed. The exploit was used aggressively before MOVEit's developer had any awareness of the vulnerability.

### IMPACT ANALYSIS

| Category     | Impact Details                                                                                                                                                                                                                                                                                                                                                                                                            |
|--------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Individual   | Most individuals have no control over this threat. If your bank or hospital is compromised through a zero-day, your data is exposed regardless of anything you personally did right or wrong. For individuals targeted directly — journalists, executives, dissidents, people of interest to nation-states — zero-days have been used to silently compromise devices with no indication anything happened.                |
| Organization | The SolarWinds case showed how severe zero-day supply chain attacks can be — an organization can do everything right and still get hit because a trusted vendor’s software was compromised before it ever reached them. Average dwell time (how long attackers stay undetected in a network) for sophisticated zero-day attacks is measured in months. By the time detection happens, the damage is usually already done. |

PREVENTIVE MEASURES

- **Defense in Depth:** No single control blocks a zero-day. But layered defenses — network segmentation, application allowlisting, endpoint behavior monitoring, user behavior analytics — mean that an attacker exploiting one layer still has more layers to get through before causing serious damage. Reducing blast radius is the realistic goal when prevention is impossible.
- **Behavioral Detection:** Since zero-days are unknown, signature-based detection cannot catch them. But behavioral analysis can — if a process is doing something unusual (calling out to unexpected external servers, moving laterally across the network, dumping credential stores), that anomaly can be flagged regardless of the specific vulnerability being exploited.
- **Bug Bounty Programs:** Organizations that run bug bounty programs are paying researchers to find vulnerabilities before attackers do. It is not free — payouts can be substantial for serious findings — but it is almost always cheaper than a breach.
- **Threat Intelligence Subscriptions:** CISA, industry ISACs, and commercial threat intelligence platforms publish rapid alerts when new zero-days are discovered and actively exploited. Subscribing to these feeds and having a process to act quickly on emergency patches dramatically reduces exposure time.

4. Threat Comparison Summary

The following table provides a consolidated overview of the five threats analyzed in this report, comparing their technical sophistication, primary targets, and overall risk rating.

| Threat                  | Primary Vector       | Main Targets          | Sophistication      | Risk Level (2025) |
|-------------------------|----------------------|-----------------------|---------------------|-------------------|
| AI-Powered Phishing     | Email / Social Media | All users and orgs    | High (AI-augmented) | CRITICAL          |
| Ransomware-as-a-Service | Phishing / RDP / VPN | SMBs, Healthcare, Gov | Medium–High         | CRITICAL          |

| Threat                  | Primary Vector           | Main Targets            | Sophistication | Risk Level (2025) |
|-------------------------|--------------------------|-------------------------|----------------|-------------------|
| Cloud Misconfigurations | Exposed APIs / Buckets   | Cloud-adopting orgs     | Low–Medium     | HIGH              |
| IoT Vulnerabilities     | Network / Default Creds  | Consumers, Enterprises  | Low–Medium     | HIGH              |
| Zero-Day Exploits       | Software vulnerabilities | High-value targets, Gov | Very High      | SEVERE            |

## 5. Conclusion and Future Scope

Researching and writing this report made one thing really clear: these are not theoretical risks. Every single threat covered here has caused massive, documented damage to real organizations and real people in the past few years. Some takeaways that stood out:

- Waiting for something to go wrong before taking security seriously is not a strategy — it is a gamble that organizations keep losing. Colonial Pipeline, Capital One, the NHS: none of them expected to be in the news. Proactive monitoring, testing, and assessment are what actually move the needle.
- People are still the easiest target. The most sophisticated firewall in the world does not stop an employee who clicks a convincing phishing link or approves a fraudulent wire transfer. Training and clear verification procedures for sensitive actions are just as important as technical controls — arguably more so in some cases.
- No single tool or control is enough. The organizations that recover fastest from incidents are the ones with multiple overlapping defenses — so that when one layer fails (and eventually, one will), there are others behind it. That is what defense in depth means in practice.
- Cloud and IoT security need to be treated as distinct disciplines, not extensions of traditional IT security. The risks are different, the tooling is different, and applying old on-premises thinking to these environments is how you end up with a public S3 bucket full of customer data.

### THE ROAD AHEAD: FUTURE THREATS AND EMERGING RISKS

Looking beyond 2025, a few trends are worth keeping an eye on:

- **Post-Quantum Cryptography:** Sufficiently powerful quantum computers could break RSA and ECC encryption — the algorithms protecting most of the internet's sensitive communications. This is not immediate, but migration to post-quantum cryptographic standards is something organizations should start planning for, not scramble to do when it becomes urgent.
- **AI on Both Sides:** Defenders are using AI to detect threats faster. Attackers are using AI to craft more convincing attacks and find vulnerabilities at scale. This arms race will define a lot of the next decade of cybersecurity. Neither side has a permanent advantage.
- **Supply Chain Targeting:** SolarWinds showed that compromising one trusted software vendor can give an attacker access to thousands of organizations simultaneously. That playbook is not

going away. Vetting third-party software and vendors for security practices is becoming a core business function, not just an IT concern.

- **Infrastructure Attacks Getting More Serious:** Power grids, water systems, hospitals, and transportation networks are increasingly attractive targets — both for ransomware groups chasing large payouts and for nation-state actors using them as geopolitical leverage. The consequences of these attacks extend well beyond data loss.

One thing that stood out throughout this research is that cybersecurity is not a problem you solve and move on from. The attackers adapt constantly. The tools change. The vulnerabilities shift. What this means practically is that staying informed — reading threat intelligence, following security researchers, understanding new attack techniques — is not optional for anyone working in this field. The organizations that handle incidents best are the ones that treated security as an ongoing priority, not a checkbox.

## 6. References

---

The sources below were used for research, case study details, and statistical data cited throughout this report:

1. **CISA Cybersecurity Alerts & Advisories.** U.S. Cybersecurity and Infrastructure Security Agency. <https://www.cisa.gov/news-events/cybersecurity-advisories>
2. **IBM Security X-Force Threat Intelligence Index 2024.** IBM Security. <https://www.ibm.com/reports/threat-intelligence>
3. **Verizon Data Breach Investigations Report 2024.** Verizon Business. <https://www.verizon.com/business/resources/reports/dbir/>
4. **ENISA Threat Landscape Report 2024.** European Union Agency for Cybersecurity. <https://www.enisa.europa.eu/topics/cyber-threats/enisa-threat-landscape>
5. **WannaCry Ransomware Attack Analysis.** UK National Cyber Security Centre. <https://www.ncsc.gov.uk/news/wannacry-guidance>
6. **Capital One Data Breach — U.S. DOJ Case.** U.S. Department of Justice. <https://www.justice.gov/usao-wdwa/pr/former-seattle-tech-worker-convicted-wire-fraud>
7. **OWASP Top 10 (2021).** Open Web Application Security Project. <https://owasp.org/www-project-top-ten/>
8. **SolarWinds Cyberattack — CISA Alert.** CISA. <https://www.cisa.gov/news-events/alerts/2020/12/17/active-exploitation-solarwinds-software>
9. **KrebsOnSecurity — Cybercrime News & Analysis.** Brian Krebs. <https://krebsonsecurity.com>
10. **Mirai Botnet Technical Analysis.** Cloudflare. <https://www.cloudflare.com/learning/ddos/glossary/mirai-botnet/>
11. **CrowdStrike Global Threat Report 2025.** CrowdStrike. <https://www.crowdstrike.com/global-threat-report/>
12. **WormGPT Analysis.** SlashNext Security. <https://slashnext.com/blog/wormgpt-the-generative-ai-tool-cybercriminals-are-using-to-launch-bec-attacks/>